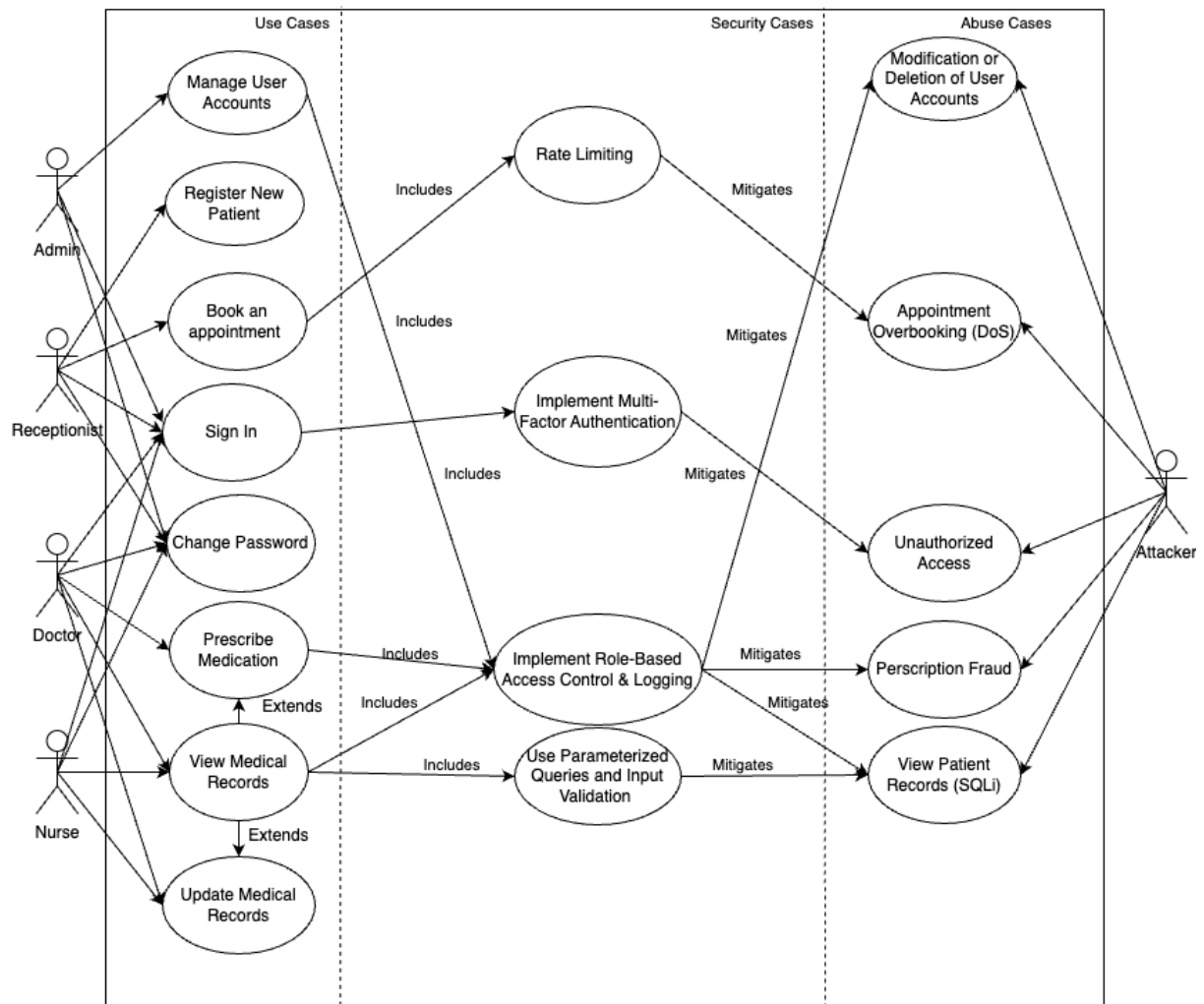


Hospital Management System
Functional and Security Requirements
Ruqaya Abdulhussein



Use Cases

Use case Id:	F001
Name:	User Sign In
Created By/Author:	Ruqaya Abdulhussein
Date Created:	7 March 2025

Actor:	Administrator, Receptionist, Doctor, Nurse
Description/Summary:	Users must be able to log into the system.. The login process includes providing login credentials.
Preconditions:	The user is registered in the system with valid credentials.
Postconditions:	The user is successfully authenticated and granted access to the system.
Normal course of events:	1. The user navigates to the login page. 2. The user enters their username and password. 3. The system verifies the credentials. 4. If authentication is successful, the user is redirected to the dashboard based on their role.
Exceptions:	If the username or password is incorrect, the system displays an error message.
Acceptance Criteria:	Users with valid credentials can log in successfully.

Use case Id:	F002
Name:	Change Password
Created By/Author:	Ruqaya Abdulhussein
Date Created:	23 March 2025
Actor:	Administrator, Receptionist, Doctor, Nurse
Description/Summary:	Users must be able to change their passwords upon logging in to the system.
Preconditions:	The user is registered in the system with valid credentials.
Postconditions:	The user successfully changes their password.
Normal course of events:	1. The user navigates to the change password page. 2. The user enters their old password and password. 3. The system verifies the old password and ensures the new password meets the complexity requirements.

	4. If password change is successful, the user is redirected back to the login back.
Exceptions:	If the old password is incorrect or new password doesn't meet complexity requirements, the system displays an error message.
Acceptance Criteria:	

Use case Id:	F002
Name:	Manage User Accounts
Created By/Author:	Ruqaya Abdulhussein
Date Created:	7 March 2025
Actor:	Administrator
Description/Summary:	The admin should be able to add, update, or remove users.
Preconditions:	The administrator is logged into the system with appropriate permissions.
Postconditions:	At least one user account is successfully created, updated, or removed. Changes are logged for auditing purposes..
Normal course of events:	1. The administrator navigates to the user management section. 2. The administrator selects an option: add, update, or remove a user 3. If adding a user, the administrator enters the required details (name, role, contact, etc.). 4. If updating, the administrator selects a user and modifies the necessary details. 5. If removing, the administrator selects a user and confirms deletion. 6. The system processes the request and displays a success message.
Exceptions:	If required fields are missing, the system prompts the administrator to complete them.

Acceptance Criteria:	The administrator can successfully add, update, or remove users.
-----------------------------	--

Use case Id:	F003
Name:	Register New Patient
Created By/Author:	Ruqaya Abdulhussein
Date Created:	7 March 2025
Actor:	Receptionist
Description/Summary:	The receptionist should be able to add patient details.
Preconditions:	The receptionist is logged into the system with appropriate permissions. The patient is not already registered in the system.
Postconditions:	The patient's information is successfully stored in the system. The patient is assigned a unique ID for future reference.
Normal course of events:	1. The receptionist navigates to the patient registration section. 2. The receptionist enters the patient's personal details (name, date of birth, contact, etc.). 3. The system validates the entered information. 4. If validation is successful, the system stores the patient's details and assigns a unique patient ID. 5. A confirmation message is displayed.
Exceptions:	If required fields are missing, the system prompts the receptionist to complete them. If the patient is already registered, the system prevents duplicate entry and notifies the receptionist.
Acceptance Criteria:	The receptionist can successfully add a new patient with complete details. The system prevents duplicate patient registrations. The patient's data is securely stored and accessible by authorized personnel.

Use case Id:	F004
Name:	Book an appointment
Created By/Author:	Ruqaya Abdulhussein
Date Created:	7 March 2025
Actor:	Receptionist
Description/Summary:	The receptionist should be able to book an appointment for a patient based on the doctor and their availability
Preconditions:	The receptionist is logged into the system with appropriate permissions. The patient is already registered in the system. Doctor availability data is up-to-date in the system.
Postconditions:	The patient is successfully assigned to a doctor.
Normal course of events:	1. The receptionist navigates to the all patients records section. 2. The receptionist searches for the patient and selects them. 3. The receptionist selects a specialty required for the patient's condition. 4. The system displays a list of available doctors based on the specialty. 5. The receptionist selects an available doctor. 6. The system confirms the appointment. 7. A confirmation message is displayed.
Exceptions:	If no doctors are available for the required specialty, the system notifies the receptionist and suggests alternatives.
Acceptance Criteria:	The receptionist can successfully assign a doctor based on specialty and availability. The system prevents double-booking of doctors. The patient's records reflect the assigned doctor.

Use case Id:	F005
Name:	Prescribe Medication
Created By/Author:	Ruqaya Abdulhussein
Date Created:	7 March 2025
Actor:	Doctor
Description/Summary:	Doctors can issue prescriptions for patients, specifying medication type, dosage, and instructions.
Preconditions:	The system successfully updates the patient's medical record and logs the changes for auditing purposes.
Postconditions	The system successfully records the prescription, making it available to the patient's medical history.
Normal course of events:	1. The doctor logs into the system. 2. The doctor navigates to the patient records section. 3. The doctor selected a patient. 4. The system retrieves the patient's medical history. 5. The doctor inputs the treatment field. 6. The doctor enters the medication details (name, dosage, frequency, and instructions). 7. The system validates and saves the prescription. 8. The system logs the prescription for auditing and patient history.
Exceptions:	- If required prescription details are missing, the system prompts the doctor to complete them.
Acceptance Criteria:	Authorized doctors can successfully prescribe medications, and prescriptions are stored in the patient's medical history.

Use case Id:	F006
Name:	View Patient Records
Created By/Author:	Ruqaya Abdulhussein
Date Created:	7 March 2025
Actor:	Doctor, Nurse
Description/Summary:	Doctors and nurses can retrieve patient history, diagnoses, and treatments.
Preconditions:	The user must be a registered Doctor or Nurse with valid credentials.
Postconditions:	The system displays the patient's medical history, diagnoses, and treatments based on access permissions.
Normal course of events:	1.The user logs into the system. 2. The user navigates to the patient records section. 3. The user selects a patient. 4. The system retrieves and displays the patient's medical history, diagnoses, and treatments.
Exceptions:	If the user does not have the correct permissions, access is denied.
Acceptance Criteria:	Authorized doctors and nurses can successfully view patient records if they have the correct permissions.

Use case Id:	F007
Name:	Update Patient Records
Created By/Author:	Ruqaya Abdulhussein
Date Created:	7 March 2025
Actor:	Doctor, Nurse
Description/Summary:	Doctors and nurses can update patient records, including diagnoses, treatments.
Preconditions:	The system successfully updates the patient's medical record and logs the changes for auditing purposes.
Postconditions:	The system displays the patient's medical history, diagnoses, and treatments based on access permissions.
Normal course of events:	1. The user logs into the system. 2. The user navigates to the patient records section. 3. The user selects a user. 4. The system retrieves the existing patient record. 5. The user updates the necessary fields (diagnosis, treatment). 6. The system validates and saves the updated information. 7. The system logs the update for auditing purposes.
Exceptions:	If the user does not have the correct permissions, access is denied.
Acceptance Criteria:	Authorized doctors and nurses can successfully update patient records with valid data, and changes are logged for auditing.

Abuse Cases

Abuse case Id:	A001
-----------------------	------

Name:	Unauthorized Access
Created By/Author:	Ruqaya Abdulhussein
Date:	7 March 2025
Priority:	High
Scope:	Hospital Management System
Development Environment:	Desktop Application
Mis-actors:	Attackers, Malicious Insiders
Access Right Levels:	Unauthorized users, Compromised user accounts
Point of Entry:	Registration page
Security Attribute Affected	Confidentiality (Sensitive staff data could be exposed). Integrity (Unauthorized modifications to user accounts). Availability (Brute-force attacks may lock legitimate users out).
Description:	An attacker attempts to gain access to the system using stolen credentials, brute-force attacks, or exploiting weak passwords.
Sophistication:	Moderate to High
Preconditions:	The login system is publicly accessible. The system does not enforce strong authentication measures (e.g., MFA, account lockout). Some users may have weak passwords.
Assumptions:	The attacker has access to credential lists from data breaches or can automate brute-force attempts. Users may not be aware of strong password policies.
Postconditions:	The attacker gains unauthorized access to the system. Sensitive patient and hospital data could be stolen or altered. Legitimate users may be locked out due to mass login attempts.
Related Use Cases:	F001 / User Sign In
Related Threats:	Credential Stuffing, Brute-Force Attacks, Phishing, Privilege Escalation
Exceptions:	N/A

Acceptance Criteria:	The attacker successfully gains access to the system using stolen or guessed credentials. The system fails to detect or prevent unauthorized access attempts.
-----------------------------	---

Abuse case Id:	A002
Name:	Unauthorized Modification or Deletion of User Accounts
Created By/Author:	Ruqaya Abdulhussein
Date:	7 March 2025
Priority:	High
Scope:	Hospital Management System
Development Environment:	Desktop Application
Mis-actors:	Compromised Admin Account, Malicious Insider
Access Right Levels:	Unauthorized users, Compromised admin accounts
Point of Entry:	User Management Section
Security Attribute Affected	Integrity (User records are altered or deleted maliciously, leading to disruption). Availability (Hospital operations are disrupted if user accounts are deleted or changed inappropriately). Confidentiality (Sensitive user data could be exposed if accounts are tampered with).
Description:	A compromised admin account or insider threat modifies or deletes staff accounts maliciously, disrupting hospital operations.
Sophistication:	Moderate to High
Preconditions:	The system has administrative access levels for staff management. An admin account or user with privileged access is compromised or intentionally malicious.
Assumptions:	The attacker has the necessary permissions or a compromised admin account.

	The system lacks sufficient logging, monitoring, or access control to detect such changes.
Postconditions:	Staff accounts are modified or deleted, potentially removing or altering critical access to the system. Hospital operations are disrupted due to unavailable or misconfigured accounts.
Related Use Cases:	F002 / Manage Staff Accounts
Related Threats:	Insider Threat, Account Compromise, Privilege Escalation, Data Corruption
Exceptions:	N/A
Acceptance Criteria:	The system fails to detect and prevent unauthorized modification or deletion of staff accounts. The attacker can disrupt hospital operations by altering or removing accounts without being caught.

Abuse case Id:	A003
Name:	Appointment Overbooking (DoS)
Created By/Author:	Ruqaya Abdulhussein
Date:	7 March 2025
Priority:	High
Scope:	Hospital Management System
Development Environment:	Desktop Application
Mis-actors:	Attackerst, Malicious Insiders , Automated Bots
Access Right Levels:	Unauthorized users, Compromised user accounts
Point of Entry:	Appointment scheduling system
Security Attribute Affected	Availability: Legitimate users are unable to book appointments due to system overload. Integrity: False appointments disrupt the hospital's workflow

Description:	Attackers exploit the hospital's appointment scheduling system by repeatedly booking appointments, leading to a denial of service (DoS) scenario where legitimate patients cannot schedule appointments
Sophistication:	Low to Moderate
Preconditions:	The hospital allows online or automated appointment booking. There are no rate-limiting mechanisms in place. The system does not verify user identities before booking appointments
Assumptions:	The attacker can generate a high number of fake appointment requests. There are no mechanisms to detect or block automated or suspicious booking patterns. The system does not require patient verification before booking.
Postconditions:	The hospital's appointment system is overloaded with fake bookings. Legitimate patients are unable to secure appointments. The hospital experiences operational disruptions
Related Use Cases:	F004 / Assign a doctor to patient
Related Threats:	Denial of Service (DoS) Resource Exhaustion
Exceptions:	N/A
Acceptance Criteria:	Attackers successfully prevent legitimate users from booking appointments by overloading the system with fake bookings. The hospital's appointment scheduling system becomes unreliable due to excessive fraudulent requests

Abuse case Id:	A004
Name:	Prescription Fraud
Created By/Author:	Ruqaya Abdulhussein
Date:	7 March 2025
Priority:	High
Scope:	Hospital Management System

Development Environment:	Desktop Application
Mis-actors:	Attackerst, Malicious Insiders
Access Right Levels:	Authorized users (Doctors) misusing privileges, Unauthorized users accessing compromised accounts
Point of Entry:	Patient Registration Section
Security Attribute Affected	Confidentiality: Unauthorized access to prescription records. Integrity: Fraudulent prescriptions issued. Availability: Misuse of hospital resources, leading to potential system abuse
Description:	A compromised doctor's account or a malicious insider issues fraudulent prescriptions for controlled substances, leading to illegal drug distribution or unauthorized patient access.
Sophistication:	Moderate
Preconditions:	The attacker has access to a compromised doctor's account or insider privileges. The system does not enforce strong authentication (e.g., multi-factor authentication, role-based access control).
Assumptions:	The attacker can manipulate the system to create unauthorized prescriptions. There is no strict validation or approval process for issuing prescriptions.
Postconditions:	Fraudulent prescriptions are successfully created and stored in the system. Illegal drug distribution or unauthorized access to controlled substances occurs.
Related Use Cases:	F004 / Prescribe Medication
Related Threats:	Identity Theft Drug Misuse and Illegal Distribution
Exceptions:	N/A
Acceptance Criteria:	A malicious actor successfully issues fraudulent prescriptions. The system does not detect or prevent unauthorized prescription activity

Abuse case Id:	A005
Name:	View Patient Records (SQLi)
Created By/Author:	Ruqaya Abdulhussein
Date:	7 March 2025
Priority:	High
Scope:	Hospital Management System
Development Environment:	Desktop Application
Mis-actors:	Attackerst, Malicious Insiders
Access Right Levels:	Unauthorized users, Compromised user accounts
Point of Entry:	Login forms, search fields, or patient record query
Security Attribute Affected	Confidentiality: Patient records could be exposed. Integrity: Attackers may modify or delete patient records. Availability: Database corruption or deletion may lead to system failure
Description:	A threat actor injects malicious SQL queries into input fields (e.g., login forms, patient search) to manipulate the hospital's database, gaining unauthorized access to view, update, or delete patient records
Sophistication:	Moderate
Preconditions:	The system does not properly validate or sanitize user input. The database queries are executed without using parameterized queries or prepared statements. Error messages or system responses provide useful information for attackers. The attacker has access to the input fields where they can inject SQL payload
Assumptions:	The attacker has access to an entry point where raw SQL queries can be injected. The system does not implement input validation, parameterized queries, or other SQL injection mitigations. Database error messages or responses reveal information that assists the attacker.

Postconditions:	The attacker successfully retrieves sensitive patient records. Unauthorized modifications or deletions of patient records may occur.
Related Use Cases:	F002 / View Patient Records
Related Threats:	Identity Theft Data Breach
Exceptions:	N/A
Acceptance Criteria:	SQL injection successfully retrieves or modifies patient records. The attacker gains unauthorized access to sensitive medical information.

Security cases

Use case Id:	S001
Name:	Rate Limiting
Created By/Author:	Ruqaya Abdulhussein
Date Created:	May 7 2025
Actor:	Hospital Management System
Description/Summary:	The system enforces rate limiting to prevent attackers or automated scripts from overwhelming the appointment booking system with excessive requests, which could lead to denial of service (DoS) for legitimate patients.
Preconditions:	A user or bot attempts to book multiple appointments within a short time frame. The system monitors booking requests per user/IP address.
Postconditions:	The system restricts excessive appointment bookings. Legitimate users can still book appointments within reasonable limits. Suspicious activity is logged and flagged for review.

Normal course of events:	1. A user requests an appointment booking. 2. The system checks the user's recent booking activity. 3. If the booking rate is within acceptable limits, the appointment is confirmed. 4. If the user exceeds the allowed threshold, the system temporarily blocks further booking attempts. 5. The system logs the event and notifies administrators if abnormal booking patterns are detected.
Exceptions:	If the system falsely detects a legitimate user as a bot, manual review can reinstate booking privileges.
Acceptance Criteria:	Automated or excessive appointment booking attempts are blocked. Rate limiting does not hinder legitimate users making reasonable bookings. The system effectively detects and mitigates DoS attempts on the appointment booking feature.

Security case Id:	S002
Name:	Implement Multi-Factor Authentication
Created By/Author:	Ruqaya Abdulhussein
Date Created:	May 7 2025
Actor:	Hospital Management System
Description/Summary:	Multi-Factor Authentication (MFA) adds an extra layer of security by requiring users to verify their identity using multiple authentication methods..
Preconditions:	The user has valid login credentials. The system must support multi-factor authentication mechanism
Postconditions:	The user is granted access only after successful multi-factor authentication. Unverified login attempts are blocked and logged.

Normal course of events:	The user enters their username and password. The system verifies credentials. If valid, the system prompts for a second authentication factor (OTP, biometric, security token). The user provides the second authentication factor. If successful, the user gains access to the system
Exceptions:	None
Acceptance Criteria:	MFA is enforced for all user logins. Unauthorized users without the second factor are denied access.

Security case

Security case Id:	S003
Name:	Implement Role-Based Access Control & Logging
Created By/Author:	Ruqaya Abdulhussein
Date Created:	May 7 2025
Actor:	Hospital Management System
Description/Summary:	Role-Based Access Control (RBAC) ensures that users can only access data and functions relevant to their role. Auditing and logging keep track of system activities for security monitoring
Preconditions:	The user has an account with assigned roles and permissions. The system supports role-based access control mechanisms.
Postconditions:	Users can only access features relevant to their roles. All system activities are logged for security and audit purposes
Normal course of events:	The user logs into the system. The system checks the user's assigned role. The user accesses only the functions and data permitted for their role.

	All actions performed are logged and monitored
Exceptions:	None
Acceptance Criteria:	Unauthorized users cannot access restricted features. All access requests and actions are logged for auditing..

Security case Id:	S004
Name:	Use Parameterized Queries and Input Validation
Created By/Author:	Ruqaya Abdulhussein
Date Created:	May 7 2025
Actor:	Hospital Management System
Description/Summary:	Parameterized queries prevent SQL Injection (SQLi) attacks by ensuring that user inputs are properly sanitized and validated before execution.
Preconditions:	The system accepts user inputs in fields such as login, search, and database queries. The database allows the execution of SQL queries
Postconditions:	The system only executes queries with validated and sanitized inputs. SQL injection attempts are blocked and logged.
Normal course of events:	The user enters input into a form field. The system validates and sanitizes the input. A parameterized query is executed with the sanitized input. The system returns the appropriate results without executing malicious code.
Exceptions:	None
Acceptance Criteria:	The system prevents SQL injection attempts.

	Inputs are sanitized before query execution.
--	--